

Sang Ah Lee
DATA-260 Section 22
Student ID: 012634544

Configuration:

SID4: 4544
PORT_BASE: 8044
PREFIX: s4544
SEED: 4544
VERIFY_SEED: 264544
DOMAIN_ID: 4 (Open_source package vulnerabilities)

Hardware: Apple M3, 16GB

Model: qwen2.5:3b (switched from qwen3.8b due to hardware issues)

Recent repo state (w/o report): 58d77b3f1c5e21da9b7ac43ad83124d98058470d

Link: <https://github.com/sangahlee0/data260-4544>

Link to HW4 Commit#:

<https://github.com/sangahlee0/data260-4544/tree/58d77b3f1c5e21da9b7ac43ad83124d98058470d> (This commit link does not include the report, because it will be added after downloading this document)

Homework 4

PART 1

- Login.jsx

```
code > web_application > frontend > src > components > Login.jsx > LoginBar
4   export default function LoginBar({ auth, setAuth }) {
46
47     return (
48       <div className="loginbar">
49         {auth.loggedIn ? (
50           <>
51             <div className="loginbar-text">
52               ✓ Logged in as <b>{auth.email}</b>
53             </div>
54             <button className="btn danger" onClick={handleLogout}>
55               Logout
56             </button>
57           </>
58         ) : (
59           <form className="loginbar-form" onSubmit={handleLogin}>
60             <div className="loginbar-text">
61               🔒 Not logged in
62             </div>
63
64             <input
65               className="loginbar-input"
66               type="email"
67               placeholder="Enter email"
68               value={email}
69               onChange={(e) => setEmail(e.target.value)}
70               required
71             />
72
73
74             <input
75               className="loginbar-input"
76               type="password"
77               placeholder="Enter Password"
78               value={password}
79               onChange={(e) => setPassword(e.target.value)}
80               required
```

🔒 Not logged in

Login

Vulnerabilities

Login first to fetch vulnerability records from the protected API.

🔒 You are not logged in. Please login.

1. Home.jsx

rag.py7,0 xcreateRecor... x! questions... 0 x03.ReactJ... 0 x02-Sessi... 0 x

code > web_application > frontend > src > pages > createRecord.jsx > CreateRecord

```
1 import React, { useState } from "react";
2
3 export default function CreateRecord({ onAdd }) {
4   const [packageName, setPackageName] = useState("");
5   const [vulnerabilityName, setVulnerabilityName] = useState("");
6
7   async function handleSubmit(e) {
8     e.preventDefault();
9     await onAdd({ package_name: packageName, vulnerability_name: vulnerabilityName });
10  }
11
12  return (
13    <div className="card">
14      <div className="card-header">
15        <div className="page-title">Add Vulnerability</div>
16        <div className="subtitle">Enter vulnerability details below</div>
17      </div>
18
19      <div className="card-body">
20        <form className="form" onSubmit={handleSubmit}>
21          <label>
22            Package Name
23            <input
24              value={packageName}
25              onChange={(e) => setPackageName(e.target.value)}
26              required
```

localhost:5173/create

✔ Logged in as admin@example.comLogout

Add VulnerabilityEnter vulnerability details below

Package Name

Vulnerability Name

Add Vulnerability

3. UpdateRecord.jsx

```
rag.py 7, U × updateRecor... × ! questions... U × 03.ReactJ... U × 02-Sessi... U ×
code > web_application > frontend > src > pages > updateRecord.jsx > UpdateRecord
1 import React, { useEffect, useState } from "react";
2 import { useParams } from "react-router-dom";
3 import { fetchVulnerabilityById } from "../api/usersApi.js";
4
5 export default function UpdateRecord({ onUpdate }) {
6   const { id } = useParams();
7   const vulnerabilityId = Number(id);
8
9   const [packageName, setPackageName] = useState("");
10  const [vulnerabilityName, setVulnerabilityName] = useState("");
11  const [loading, setLoading] = useState(true);
12
13  useEffect(() => {
14    (async () => {
15      try {
16        setLoading(true);
17        const vulnerability = await fetchVulnerabilityById(vulnerabilityId);
18        setVulnerabilityName(vulnerability.vulnerability_name);
19        setPackageName(vulnerability.package_name);
20      } catch (e) {
21        console.error(e);
22      } finally {
23        setLoading(false);
24      }
25    })();
26  }, [vulnerabilityId]);
```

✔ Logged in as admin@example.com

Logout

Update Vulnerability (ID: 1)

Package Name

flask-0

Vulnerability Name

Cross-Site Scripting

Update Vulnerability

4. Delete Record.jsx

```
code > web_application > frontend > src > pages > deleteRecord.jsx > DeleteRecord
1  import React, { useEffect, useState } from "react";
2  import { useParams } from "react-router-dom";
3  import { fetchVulnerabilityById } from "../api/usersApi.js";
4
5  export default function DeleteRecord({ onDelete }) {
6      const { id } = useParams();
7      const vulnerabilityId = Number(id);
8
9      const [vulnerability, setVulnerability] = useState(null);
10
11     useEffect(() => {
12         (async () => {
13             try {
14                 const data = await fetchVulnerabilityById(vulnerabilityId);
15                 setVulnerability(data);
16             } catch {
17                 setVulnerability(null);
18             }
19         })();
20     }, [vulnerabilityId]);
21
22     async function handleDelete() {
23         await onDelete(vulnerabilityId);
24     }

```

localhost:5173/delete/1

✔ Logged in as admin@example.com

Logout

Delete Vulnerability

Are you sure you want to delete **Cross-Site Scripting (flask-0)**?

Delete Vulnerability

5. Components

```

rag.py 7, U × {} package.json × ! questions... U × 03.ReactJ... U × 02
code > web_application > frontend > {} package.json > {} dependencies > abc react-router-dom
1  {
2    "name": "frontend",
3    "private": true,
4    "version": "1.0.0",
5    "type": "module",
6    >Debug
7    "scripts": {
8      "dev": "vite",
9      "build": "vite build",
10     "preview": "vite preview"
11   },
12   "dependencies": {
13     "axios": "^1.6.0",
14     "react": "^18.2.0",
15     "react-dom": "^18.2.0",
16     "react-router-dom": "^6.22.3"
17   },
18   "devDependencies": {
19     "@vitejs/plugin-react": "^4.2.0",
20     "vite": "^5.0.0"
21   }

```

```

code > web_application > frontend > src > components > Login.jsx > ...
1  import React, { useEffect, useState } from "react";
2  import { login, logout, me } from "../api/usersApi.js";
3

```

Create-

```

rag.py 7, U × createReco... × ! questions... U × 03.ReactJ... U × 02-Sessi... U ×
code > web_application > frontend > src > pages > createRecord.jsx > CreateRecord > handleSubmit
1  import React, { useState } from "react";
2
3  export default function CreateRecord({ onAdd }) {
4    const [packageName, setPackageName] = useState("");
5    const [vulnerabilityName, setVulnerabilityName] = useState("");
6
7    async function handleSubmit(e) {
8      e.preventDefault();
9      await onAdd({ package_name: packageName, vulnerability_name: vulnerabilityName });
10   }
11

```

Update-

```
rag.py 7, U × updateRecor... × ! questions... U × 03.ReactJ... U × 02-Sessi... U × 03-Prom... U × 0
code > web_application > frontend > src > pages > updateRecord.jsx > UpdateRecord > handleSubmit
5 export default function UpdateRecord({ onUpdate }) {
13   useEffect(() => {
14     (async () => {
23       setLoading(false);
24     })();
25   }, [vulnerabilityId]);
26
27   async function handleSubmit(e) {
28     e.preventDefault();
29     await onUpdate(vulnerabilityId, { package_name: packageName, vulnerability_name: vulnerabilityName });
30   }
31
32   if (loading) return <p>Loading vulnerability...</p>;
33
34 }
```

Delete-

```
rag.py 7, U × deleteRecor... × ! questions... U × 03.ReactJ... U × 02-Sessi... U
code > web_application > frontend > src > pages > deleteRecord.jsx > DeleteRecord > useEffect() callb
5 import { fetchVulnerabilityById } from '../api/userAPI.js';
6
7 export default function DeleteRecord({ onDelete }) {
8   const { id } = useParams();
9   const vulnerabilityId = Number(id);
10
11   const [vulnerability, setVulnerability] = useState(null);
12
13   useEffect(() => {
14     (async () => {
15       try {
16         const data = await fetchVulnerabilityById(vulnerabilityId);
17         setVulnerability(data);
18       } catch {
19         setVulnerability(null);
20       }
21     })();
22   }, [vulnerabilityId]);
23 }
```

PART 2

- Create Database and Tables

```
rag.py 7, U × ! questions.y... U × models.py 2 ×
code > web_application > backend > models.py > VulnerabilityDescription
6 class Vulnerability(Base):
11     vulnerability_name = Column(String(255), nullable=False)
12
13 class User(Base):
14     __tablename__ = "users"
15
16     id = Column(Integer, primary_key=True, index=True, autoincrement=True)
17     name = Column(String(255), nullable=False)
18     email = Column(String(255), nullable=False, unique=True)
19     password_hash = Column(String(255), nullable=False)
20
21
22 class SessionToken(Base):
23     __tablename__ = "sessions"
24
25     id = Column(String(64), primary_key=True, index=True) # session token
26     user_id = Column(Integer, ForeignKey("users.id", ondelete="CASCADE"), nullable=False)
27     created_at = Column(DateTime(timezone=True), server_default=func.now())
28     expires_at = Column(DateTime(timezone=True), nullable=False)
29
```

```
version for the right syntax to use near 'USER s4544_rel' at line 1
mysql> USE s4544_rel;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

```
Database changed
mysql> SHOW TABLES;
+-----+
| Tables_in_s4544_rel |
+-----+
| sessions            |
| users               |
| vulnerabilities    |
+-----+
3 rows in set (0.00 sec)
```

- CRUD

```
rag.py 7, U × ! questions.y... U × crud.py 1 ×
code > web_application > backend > crud.py > ...
1 from sqlalchemy.orm import Session
2 from . import models, schema
3 from datetime import datetime, timedelta, timezone
4
5
6 def create_vulnerability(db: Session, payload: schema.VulnerabilityCreate):
7     vulnerability = models.Vulnerability(package_name=payload.package_name, vulnerability_name=payload.vulnerability_name)
8     db.add(vulnerability)
9     db.commit()
10    db.refresh(vulnerability)
11    return vulnerability
12
13 def get_vulnerabilities(db: Session):
14     return db.query(models.Vulnerability).order_by(models.Vulnerability.id.asc()).all()
15
16 def get_vulnerability(db: Session, vulnerability_id: int):
17     return db.query(models.Vulnerability).filter(models.Vulnerability.id == vulnerability_id).first()
18
19 def update_vulnerability(db: Session, vulnerability_id: int, payload: schema.VulnerabilityUpdate):
20     vulnerability = get_vulnerability(db, vulnerability_id)
21     if not vulnerability:
22         return None
23     vulnerability.package_name = payload.package_name
24     vulnerability.vulnerability_name = payload.vulnerability_name
25     db.commit()
26     db.refresh(vulnerability)
27     return vulnerability
28
29 def delete_vulnerability(db: Session, vulnerability_id: int):
30     vulnerability = get_vulnerability(db, vulnerability_id)
31     if not vulnerability:
32         return None
33     db.delete(vulnerability)
```

Add new record

```
@app.post("/api/vulnerabilities", response_model=schema.VulnerabilityOut, status_code=201)
def create_vulnerability(vulnerability_data: schema.VulnerabilityCreate, db: Session = Depends(get_db), _session=Depends(request_session)):
    if not vulnerability_data.package_name.strip():
        raise HTTPException(status_code=400, detail="Package name is required")

    # Create vulnerability in MySQL
    return crud.create_vulnerability(db, vulnerability_data)
```

Get new records

```
# Get all vulnerabilities
@app.get("/api/vulnerabilities")
def get_vulnerabilities(response: Response, search: str | None = None, page_size: int = 10, db: Session = Depends(get_db), _session=Depends(request_session)):
    global sql_query_count
    sql_query_count = 0

    response.headers["Cache-Control"] = "no-cache, no-store, must-revalidate"
    response.headers["Pragma"] = "no-cache"
    response.headers["Expires"] = "0"

    # Get vulnerabilities
    vulnerabilities = crud.get_vulnerabilities(db, search=search, page_size=page_size)
```

Get record by ID

```
# get by ID
@app.get("/api/vulnerabilities/{vulnerability_id}", response_model=schema.VulnerabilityOut)
def get_vulnerability_by_id(vulnerability_id: int, db: Session = Depends(get_db), _session=Depends(require_session)):
    vulnerability = crud.get_vulnerability(db, vulnerability_id)
    if not vulnerability:
        raise HTTPException(
            status_code=404,
            detail="Vulnerability not found"
        )

    return vulnerability
```

Update record

```
# Update vulnerability using the ID
@app.put("/api/vulnerabilities/{vulnerability_id}", response_model=schema.VulnerabilityOut)
def update_record(vulnerability_id: int, payload: schema.VulnerabilityUpdate, db: Session = Depends(get_db), _session=Depends(require_session)):
    """Update an existing vulnerability - Accepts JSON with vulnerability details"""
    if not payload.package_name.strip():
        raise HTTPException(status_code=400, detail="Package name is required")

    vulnerability = crud.update_vulnerability(db, vulnerability_id, payload)

    if not vulnerability:
        raise HTTPException(status_code=404, detail="Vulnerability not found")

    return vulnerability
```

Delete record

```
# DELETE
@app.delete("/api/vulnerabilities/{vulnerability_id}", response_model=schema.VulnerabilityOut)
def delete_vulnerability(vulnerability_id: int, db: Session = Depends(get_db), _session=Depends(require_session)):
    """Delete a vulnerability by ID"""
    vulnerability = crud.delete_vulnerability(db, vulnerability_id)
    if not vulnerability:
        raise HTTPException(status_code=404, detail="Vulnerability not found")

    return vulnerability
```

- Database Descriptions

```
mysql> DESCRIBE vulnerabilities;
```

Field	Type	Null	Key	Default	Extra
id	int	NO	PRI	NULL	auto_increment
package_name	varchar(255)	NO		NULL	
vulnerability_name	varchar(255)	NO		NULL	

```
3 rows in set (0.02 sec)
```

```
mysql> DESCRIBE users;
```

Field	Type	Null	Key	Default	Extra
id	int	NO	PRI	NULL	auto_increment
name	varchar(255)	NO		NULL	
email	varchar(255)	NO	UNI	NULL	
password_hash	varchar(255)	NO		NULL	

4 rows in set (0.00 sec)

```
mysql> DESCRIBE sessions;
```

Field	Type	Null	Key	Default	Extra
id	varchar(64)	NO	PRI	NULL	DEFAULT_GENERATED
user_id	int	NO	MUL	NULL	
created_at	datetime	YES		now()	
expires_at	datetime	NO		NULL	

4 rows in set (0.00 sec)

```
mysql> SELECT * FROM users;
```

id	name	email	password_hash
1	Admin	admin@example.com	\$argon2id\$v=19\$m=65536,t=3,p=4\$I//KuPfbDqnD36DBlmQ1fQ\$xm0ho9b0c9YYg7iTf+s9uVpNOT0/mgpJnFyB0

1 row in set (0.00 sec)



My Collection > Post data



Save



Share



POST



http://localhost:8044/auth/login

Send



Docs



Params

Authorization

Headers 10

Body

Scripts

Settings

Cookies

raw



JSON



Schema

Beautify

```
1 {  
2   "email": "admin@example.com",  
3   "password": "password"  
4 }
```

Body



200 OK



155 ms



303 B



e.g.

Save Response



JSON



Preview



Visualize



```
1 {  
2   "user_id": 1,  
3   "email": "admin@example.com"  
4 }
```

HTTP

My Collection > Post data

Save

Share

POST

http://localhost:8044/api/vulnerabilities

Send

Docs

Params

Authorization

Headers 10

Body

Scripts

Settings

Cookies

raw

JSON

Schema

Beautify

```
1 {
2   "package_name": "express",
3   "vulnerability_name": "SQL Injection"
4 }
```

Body

201 Created • 34 ms • 202 B

Save Response

JSON

Preview

Visualize

```
1 {
2   "id": 1,
3   "package_name": "express",
4   "vulnerability_name": "SQL Injection"
5 }
```

HTTP

My Collection > Get data

Save

Share

GET

http://localhost:8044/api/vulnerabilities

Send

Docs

Params

Authorization

Headers 8

Body

Scripts

Settings

Cookies

Query Params

Key	Value	Description	Bulk Edit	...
Key	Value	Description		

Body

200 OK • 19 ms • 281 B

Save Response

JSON

Preview

Visualize

```
1 [
2   {
3     "id": 1,
4     "package_name": "express",
5     "vulnerability_name": "SQL Injection"
6   }
7 ]
```

HTTP My Collection > Get data Save Share

GET ▼ http://localhost:8044/api/vulnerabilities/1 Send ▼

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
Key	Value	Description		

Body ▼ ↺ 200 OK • 12 ms • 197 B • 🌐 | e.g. Save Response ...

{} JSON ▼ ▶ Preview 🖼️ Visualize ▼ ≡ 🔍 📄 🔗

```
1 {
2   "id": 1,
3   "package_name": "express",
4   "vulnerability_name": "SQL Injection"
5 }
```

HTTP My Collection > New Request Save Share

PUT ▼ http://localhost:8044/api/vulnerabilities/3 Send ▼

Docs Params Authorization Headers 10 Body Scripts Settings Cookies

raw ▼ JSON ▼ 🔗 Schema Beautify

```
1 {
2   "package_name": "express",
3   "vulnerability_name": "SQL Scripting"
4 }
```

Body ▼ ↺ 200 OK • 18 ms • 197 B • 🌐 | e.g. Save Response ...

{} JSON ▼ ▶ Preview 🖼️ Visualize ▼ ≡ 🔍 📄 🔗

```
1 {
2   "id": 3,
3   "package_name": "express",
4   "vulnerability_name": "SQL Scripting"
5 }
```

My Collection > New Request

DELETE http://localhost:8044/api/vulnerabilities/1

Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
Key	Value	Description		

Body Cookies 1 Headers 4 Test Results 200 OK • 24 ms • 197 B • Save Response

{ } JSON Preview Visualize

```
1 {
2   "id": 1,
3   "package_name": "express",
4   "vulnerability_name": "SQL Injection"
5 }
```

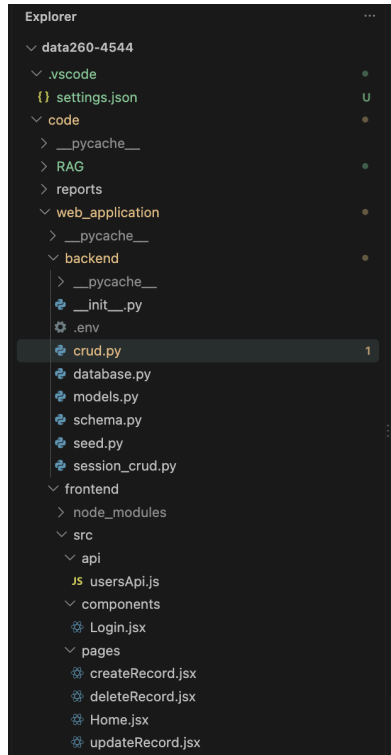
After the sessions:

```
mysql> SELECT * FROM sessions;
+-----+-----+-----+-----+
| id | user_id | created_at | expires_at |
+-----+-----+-----+-----+
| 211f4a9adb90803aef9376b955e5ed462cfad52bf21bf289f279a9ab114c3086 | 1 | 2026-09-26 22:22:34 | 2026-09-27 05:52:34 |
| 6fc5055649da0e2353613db6c6d99ef6498c62c91bbb2d1be8bcdff0cf39f7e | 1 | 2026-09-26 22:44:48 | 2026-09-27 06:14:48 |
+-----+-----+-----+-----+
2 rows in set (0.00 sec)
```

```
mysql> SELECT * FROM vulnerabilities;
+-----+-----+-----+
| id | package_name | vulnerability_name |
+-----+-----+-----+
| 2 | express | SQL Injection |
+-----+-----+-----+
1 row in set (0.00 sec)
```

```
mysql> SELECT * FROM users;
+----+-----+-----+-----+
| id | name | email | password_hash |
+----+-----+-----+-----+
| 1 | Admin | admin@example.com | $argon2id$v=19$m=65536,t=3,p=4$I//KuPfbdqnD36DBlmQ1fQ$xm0ho9b0c9YYg7iTf+s9uVpN0T0/mgpJnFyB0iNms |
+----+-----+-----+-----+
1 row in set (0.01 sec)
```

- Project folder structure



PART 3

1.

```
# Create table related table for testing
class VulnerabilityDescription(Base):
    __tablename__ = "vulnerability_description"

    id = Column(Integer, primary_key=True, index=True, autoincrement=True)
    vulnerability_id = Column(Integer, ForeignKey("vulnerabilities.id", ondelete="CASCADE"), nullable=False)
    description = Column(String(255), nullable=False)
```

```
((venv) ) (base) sangah@MacBook-Air-4 web_application % python3 -m backend.seed 2>&1 | tee -a ../../reports/hw04/RUN_LOG.txt
Finished generating 5000 vulnerabilities.
Finished generating 200 vulnerability descriptions.
((venv) ) (base) sangah@MacBook-Air-4 web_application %
```

```
Database changed
mysql> SHOW TABLES;
+-----+
| Tables_in_s4544_rel |
+-----+
| sessions            |
| users               |
| vulnerabilities     |
| vulnerability_description |
+-----+
4 rows in set (0.01 sec)
```

```
mysql> SELECT COUNT(*) FROM vulnerabilities;
+-----+
| COUNT(*) |
+-----+
|      5000 |
+-----+
1 row in set (0.00 sec)

mysql> SELECT COUNT(*) FROM vulnerability_description;
+-----+
| COUNT(*) |
+-----+
|       200 |
+-----+
1 row in set (0.00 sec)
```

```
mysql> SELECT * FROM vulnerabilities LIMIT 5;
+-----+-----+-----+
| id | package_name | vulnerability_name |
+-----+-----+-----+
| 1 | flask-0      | Cross-Site Scripting |
| 2 | numpy-1      | Path Traversal      |
| 3 | pandas-2     | Path Traversal      |
| 4 | react-3      | Command Injection    |
| 5 | flask-4      | Information Disclosure |
+-----+-----+-----+
5 rows in set (0.00 sec)
```

```
mysql> SELECT * FROM vulnerability_description LIMIT 5;
+-----+-----+-----+
| id | vulnerability_id | description |
+-----+-----+-----+
| 1 | 1132             | Affects older package versions |
| 2 | 2756             | Input validation issue detected |
| 3 | 4599             | Dependency should be upgraded |
| 4 | 1909             | Patch available |
| 5 | 1552             | Potential exploit identified |
+-----+-----+-----+
5 rows in set (0.00 sec)
```

2.

```
# Create table related table for testing
class VulnerabilityDescription(Base):
    __tablename__ = "vulnerability_description"

    id = Column(Integer, primary_key=True, index=True, autoincrement=True)
    vulnerability_id = Column(Integer, ForeignKey("vulnerabilities.id", ondelete="CASCADE"), nullable=False)
    description = Column(String(255), nullable=False)
```

```
mysql> SELECT
->     vd.id AS description_id,
->     vd.vulnerability_id,
->     v.package_name,
->     v.vulnerability_name,
->     vd.description
-> FROM vulnerability_description vd
-> JOIN vulnerabilities v
->     ON vd.vulnerability_id = v.id
-> LIMIT 5;
```

description_id	vulnerability_id	package_name	vulnerability_name	description
1	1132	react-1131	Path Traversal	Affects older package versions
2	2756	express-2755	Denial of Service	Input validation issue detected
3	4599	requests-4598	Remote Code Execution	Dependency should be upgraded
4	1909	react-1908	Cross-Site Scripting	Patch available
5	1552	requests-1551	SQL Injection	Potential exploit identified

5 rows in set (0.04 sec)

```
mysql> SHOW CREATE TABLE vulnerability_description;
```

```
+-----+
| Table | Create Table |
+-----+
| vulnerability_description | CREATE TABLE `vulnerability_description` (
  `id` int NOT NULL AUTO_INCREMENT,
  `vulnerability_id` int NOT NULL,
  `description` varchar(255) NOT NULL,
  PRIMARY KEY (`id`),
  KEY `vulnerability_id` (`vulnerability_id`),
  KEY `ix_vulnerability_description_id` (`id`),
  CONSTRAINT `vulnerability_description_ibfk_1` FOREIGN KEY (`vulnerability_id`) REFERENCES `vulnerabilities` (`id`) ON DELETE CASCADE
) ENGINE=InnoDB AUTO_INCREMENT=201 DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_0900_ai_ci |
```

1 row in set (0.01 sec)

My Collection > **Get vuln after test**

Save

Share

GET

http://localhost:8044/api/vulnerabilities

Send

Docs

Params

Authorization

Headers 8

Body

Scripts

Settings

Cookies

Body

200 OK • 69 ms • 1.19 KB • Save Response

JSON

Preview

Visualize

```

1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10         }
11      ]
12    },
13    {
14      "id": 2,
15      "package_name": "numpy-1",
16      "vulnerability_name": "Path Traversal",
17      "descriptions": []
18    },
19    {
20      "id": 3,
21      "package_name": "pandas-2",
22      "vulnerability_name": "Path Traversal",
23      "descriptions": []
24    },
25    {
26      "id": 4,
27      "package_name": "react-3",
28      "vulnerability_name": "Command Injection".

```

```

for vulnerability in vulnerabilities:
    # Merge tables
    descriptions = db.query(models.VulnerabilityDescription).filter(models.VulnerabilityDescription.vulnerability_id == vulnerability.id).all()

    results.append({
        "id": vulnerability.id,
        "package_name": vulnerability.package_name,
        "vulnerability_name": vulnerability.vulnerability_name,
        "descriptions": [{ "id": description.id, "description": description.description } for description in descriptions]
    })

```

3.

```

# Get vulnerabilities
vulnerabilities = crud.get_vulnerabilities(db)

if search:
    search = search.lower()
    vulnerabilities = [v for v in vulnerabilities if search in v.package_name.lower() or search in v.vulnerability_name.lower()]

# Limit results based on page size (10, 50, 200)
vulnerabilities = vulnerabilities[:page_size]

results = []
# Get the related description for each vulnerability
for vulnerability in vulnerabilities:
    # Merge tables
    descriptions = db.query(models.VulnerabilityDescription).filter(models.VulnerabilityDescription.vulnerability_id == vulnerability.id).all()

    results.append({
        "id": vulnerability.id,
        "package_name": vulnerability.package_name,
        "vulnerability_name": vulnerability.vulnerability_name,
        "descriptions": [{"id": description.id, "description": description.description} for description in descriptions]
    })

```

4.

```

Page size: 10
Queries/request: 11
p50: 33.33 ms
p95: 35.68 ms
p99: 51.40 ms

Page size: 50
Queries/request: 51
p50: 39.94 ms
p95: 42.55 ms
p99: 43.55 ms

Page size: 200
Queries/request: 201
p50: 57.55 ms
p95: 61.30 ms
p99: 62.92 ms

```

5.

Before:

My Collection > Get vuln after test

SaveShare

GEThttp://localhost:8044/api/vulnerabilitiesSend

DocsParamsAuthorizationHeaders 8BodyScriptsSettingsCookies

Headers200 OK • 94 ms • 1.21 KB • Save Response

Key	Value
Date	Sun, 27 Sep 2026 08:10:46 GMT
Server	uvicorn
Content-Length	1012
Content-Type	application/json
Cache-Control	no-cache, no-store, must-revalidate
Pragma	no-cache
Expires	0
X-Query-Count	11

After:

GEThttp://localhost:8044/api/vulnerabilities-fixed?page_size=10Send

DocsParamsAuthorizationHeaders 8BodyScriptsSettingsCookies

HeadersHide auto-generated headers

Key	Value	Descr...	Bulk Edit	Presets	
✓ Cookie	session_id=78796d945abfad2b3...				
✓ Cache-Control	no-cache				
✓ Postman-Token	<calculated when request is sent>				
✓ Host	<calculated when request is sent>				
✓ User-Agent	PostmanRuntime/0.0.0				

Headers200 OK • 13 ms • 1.13 KB • Save Response

Key	Value
Date	Sun, 27 Sep 2026 08:07:19 GMT
Server	uvicorn
Content-Length	1012
Content-Type	application/json
X-Query-Count	2

```
((venv) ) (base) sangah@MacBook-Air-4 code % (echo "===== "; python3 -m hw4_benchmark) 2>&1 |
txt
p50: 40.92 ms
p99: 40.92 ms

Version: fixed

Page size: 50
Queries/request: 51
p50: 41.17 ms
p95: 47.31 ms
p99: 49.91 ms

Version: fixed

Page size: 200
Queries/request: 201
p50: 58.35 ms
p95: 76.02 ms
p99: 98.62 ms
((venv) ) (base) sangah@MacBook-Air-4 code % (echo "===== "; python3 -m hw4_benchmark) 2>&1 |
txt
=====
Successfully logged in

Version: naive

Page size: 10
Queries/request: 11
p50: 34.46 ms
p95: 40.07 ms
p99: 51.08 ms

Version: naive

Page size: 50
Queries/request: 51
p50: 39.74 ms
p95: 43.36 ms
```

```
def get_vulnerabilities_fixed(response: Response, page_size: int = 10, db: Session = Depends(get_db), _session=Depends(require_session))

    # Get vulnerabilities and their descriptions using a JOIN
    # First get exactly the requested number of vulnerability IDs
    vulnerability_ids = [row.id
        for row in (db.query(models.Vulnerability.id).order_by(models.Vulnerability.id.asc())
            .limit(page_size).all())
    ]

    # JOIN vulnerabilities with their descriptions
    rows = (
        db.query(
            models.Vulnerability,
            models.VulnerabilityDescription
        )
        .outerjoin(
            models.VulnerabilityDescription,
            models.Vulnerability.id
            == models.VulnerabilityDescription.vulnerability_id
        )
        .filter(
            models.Vulnerability.id.in_(vulnerability_ids)
        )
        .order_by(models.Vulnerability.id.asc())
        .all()
    )

    results = {}
```

6.

```
The data saved in a csv found in '../reports/hw04/raw.'
((venv) ) (base) sangah@MacBook-Air-4 code % wc -l ../reports/hw04/raw/benchmark_raw.csv
181 ../reports/hw04/raw/benchmark_raw.csv
((venv) ) (base) sangah@MacBook-Air-4 code % █
```

```
reports > hw04 > raw >  benchmark_raw.csv
```

```
1 run,version,page_size,query_count,latency_ms
2 1,naive,10,11,28.781083005014807
3 2,naive,10,11,41.31237501860596
4 3,naive,10,11,36.11399998771958
5 4,naive,10,11,22.16604197747074
6 5,naive,10,11,37.85341698676348
7 6,naive,10,11,26.304250000976026
8 7,naive,10,11,37.1106659877114
9 8,naive,10,11,37.04075000132434
10 9,naive,10,11,23.044166999170557
11 10,naive,10,11,36.178915994241834
12 11,naive,10,11,22.330708015942946
13 12,naive,10,11,35.178542020730674
14 13,naive,10,11,37.93370898347348
15 14,naive,10,11,24.11766699515283
16 15,naive,10,11,35.955291998106986
17 16,naive,10,11,23.062125022988766
```

7. The fixed version at each page size, when compared at p50(ms), is 18.33 times faster for 10 pages, 16.85 times faster for 50 pages, and 10.74 times for 200 pages. The speed-up decreases as the page size grows because it would require more records to be retrieved and processed as the page size increases. However, the fixed version is faster than the naive version, as the fixed version allows tables to search without running a separate query for every vulnerability (using JOIN in this case), whereas the naive version processes more queries for each vulnerability.

8.

```
mysql>
mysql> EXPLAIN
-> SELECT *
-> FROM vulnerabilities
-> WHERE package_name = 'flask-0';
```

id	select_type	table	partitions	type	possible_keys	key	key_len	ref	rows	filtered	Extra
1	SIMPLE	vulnerabilities	NULL	ALL	NULL	NULL	NULL	NULL	5000	10.00	Using where

```
1 row in set, 1 warning (0.00 sec)
```

```
mysql> █
```

```
mysql> CREATE INDEX idx_package_name
-> ON vulnerabilities(package_name);
Query OK, 0 rows affected (0.05 sec)
Records: 0 Duplicates: 0 Warnings: 0
```

```
mysql> EXPLAIN
-> SELECT *
-> FROM vulnerabilities
-> WHERE package_name = 'flask-0';
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| id | select_type | table | partitions | type | possible_keys | key | key_len | ref | rows | filtered | Extra |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | SIMPLE | vulnerabilities | NULL | ref | idx_package_name | idx_package_name | 1022 | const | 1 | 100.00 | NULL |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
1 row in set, 1 warning (0.00 sec)

mysql>
1 row in set, 1 warning (0.00 sec)

mysql> SHOW INDEX FROM vulnerabilities;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| Table | Non_unique | Key_name | Seq_in_index | Column_name | Collation | Cardinality | Sub_part | Packed | Null | Index_type | Comment |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| vulnerabilities | 0 | PRIMARY | 1 | id | A | 5000 | NULL | NULL | NULL | BTREE | | |
| vulnerabilities | YES | NULL | 1 | idx_vulnerabilities_id | A | 5000 | NULL | NULL | NULL | BTREE | |
| vulnerabilities | YES | 1 | idx_package_name | 1 | package_name | A | 5000 | NULL | NULL | BTREE | |
| vulnerabilities | YES | NULL | | | | | | | | | | |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
3 rows in set (0.01 sec)
```

Previously, the table used a full table scan, but after the new index was added, MySQL was able to estimate that only 1 row needs to be required following the new index addition, allowing us to locate records using the package_name information instead of going through the entire table.

9.

- Naive 10

Naive > 10

Save Share

GET

http://localhost:8044/api/vulnerabilities?page_size=10

Send

Docs Params Authorization Headers 10 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
☒ page_size	10			
Key	Value	Description		

Body

200 OK 52 ms 1.21 KB Save Response

JSON

Preview Visualize

```
1 [
2   {
3     "id": 1,
4     "package_name": "flask-0",
5     "vulnerability_name": "Cross-Site Scripting",
6     "descriptions": [
7       {
8         "id": 44,
9         "description": "Automated scan detected vulnerability"
10      }
11    ]
12  },
13  {
14    "id": 2,
15    "package_name": "numpy-1",
16    "vulnerability_name": "Path Traversal",
17    "descriptions": []
18  },
19  {
20    "id": 3,
```

- Naive 50

GET http://localhost:8044/api/vulnerabilities?page_size=50

Send

Docs Params Authorization Headers 8 Body Scripts Settings

Cookies

Query Params

Key	Value	Description	Bulk Edit	...
✓ page_size	50			
Key	Value	Description		

Body 200 OK • 104 ms • 5 KB • Save Response

{ } JSON Preview Visualize

```
1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10       }
11     ]
12   },
13   {
14     "id": 2,
15     "package_name": "numpy-1",
16     "vulnerability_name": "Path Traversal",
17     "descriptions": []
18   },
19   {
```

- Naive 200

HTTP Naive > 200

Save Share

GET http://localhost:8044/api/vulnerabilities?page_size=200

Send

Docs Params Authorization Headers 8 Body Scripts Settings

Cookies

Body 200 OK • 91 ms • 19.68 KB • Save Response

JSON Preview Visualize

Copy Search Copy Link

```
1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10       }
11     ]
12   },
13   {
14     "id": 45,
```

- Fixed 10

HTTP Fixed > 10

Save Share

GET http://localhost:8044/api/vulnerabilities-fixed?page_size=10

Send

Docs Params Authorization Headers 8 Body Scripts Settings

Cookies

Body Cookies 1 Headers 5 Test Results 200 OK • 24 ms • 1.13 KB • Save Response

JSON Preview Visualize

Copy Search Copy Link

```
1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10       }
11     ]
12   },
13   {
14     "id": 45,
```

- Fixed 50

HTTP Fixed > 50 Save Share

GET http://localhost:8044/api/vulnerabilities-fixed?page_size=50 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Body Cookies 1 Headers 5 Test Results 200 OK • 13 ms • 4.92 KB • Save Response

{ } JSON Preview Visualize

```
1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10       }
11     ]
12   },
13   {
```

- Fixed 200

HTTP Fixed > 200 Save Share

GET http://localhost:8044/api/vulnerabilities-fixed?page_size=200 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

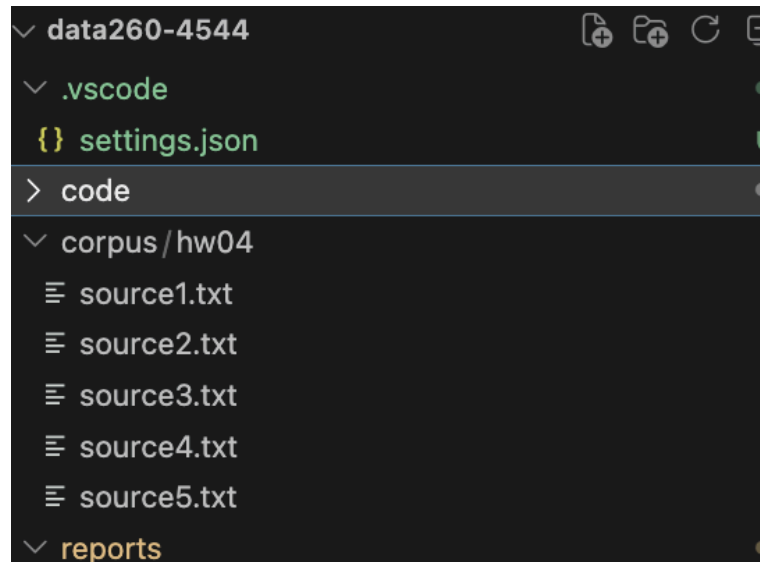
Body Cookies 1 Headers 5 Test Results 200 OK • 17 ms • 19.6 KB • Save Response

{ } JSON Preview Visualize

```
1  [
2    {
3      "id": 1,
4      "package_name": "flask-0",
5      "vulnerability_name": "Cross-Site Scripting",
6      "descriptions": [
7        {
8          "id": 44,
9          "description": "Automated scan detected vulnerability"
10       }
11     ]
12   },
13   {
```

PART 4

1. Corpus and index



```
# For moderately sized chunks without creating excessive duplication
TOKEN_CHUNK_SIZE = 500
TOKEN_CHUNK_OVERLAP = 50
TOP_K = 3

def load_documents():
    # Load the local document
    documents = SimpleDirectoryReader(input_dir=str(CORPUS_DIR)).load_data()

    # For the printed document
    print(f"Documents loaded: {len(documents)}")
    return documents

##### Indexing (in memory) #####
def build_index(nodes, embed_model):
    vector_store = SimpleVectorStore()
    storage_context = StorageContext.from_defaults(vector_store=vector_store)
    return VectorStoreIndex(nodes, storage_context=storage_context, embed_model=embed_model)
```

2. Retrieval

```

> rag.py > ...
##### Retrieval #####
def retriever_helper(index, query, k=3):
    retriever = VectorIndexRetriever(index=index, similarity_top_k=k)

    # Start time
    start_time = time.perf_counter()

    results = retriever.retrieve(query)

    retrieval_latency_ms = (time.perf_counter() - start_time) * 1000

    print(f"Retrieval latency: {retrieval_latency_ms:.2f} ms")
    print("-" * 60)

    # For each, compute returned chunk's embedding
    for rank, result in enumerate(results, start=1):
        text = result.node.get_content() # Each result has retrieved text chunk and similarity score

        source_file = result.node.metadata.get("file_name", "Unknown")

        if source_file is None:
            source_path = result.node.metadata.get("file_path")
            source_file = Path(source_path).name if source_path else None

        store_score = float(result.score) if result.score is not None else None

        print(f"\nRank: {rank}")
        print(f"Source: {source_file}")
        print(f"Score: {result.score}")
        print(f"Preview: {text[:300]}")

```

3. 3 configurations

```

# No RAG for baseline
def no_rag(query):
    messages = [{"role": "user", "content": query}]

    response = complete(messages)
    return response

# Basic RAG - top 3 chunks in prompt
def basic_rag(query, results):
    context = "\n\n".join(result.node.get_content() for result in results)

    messages = [{"role": "user", "content": f""""Use the input context to answer the query.
    Context: {context}
    Query: {query}"""]}

    response = complete(messages)
    return response

```

```

# Context-engineered RAG
def context_rag(query, results):
    unique_context = []
    seen_context = set()
    for r in results:
        text = r.node.get_content()
        # Don't include duplicate chunks
        new_text = " ".join(text.lower().split())
        if new_text in seen_context:
            continue
        # Drop irrelevant chunks using the threshold
        if r.score is not None and r.score < RELEVANCE_THRESHOLD:
            continue

        seen_context.add(new_text)
        unique_context.append(r)

    context_info = []
    # Order and label survivors with their sources
    for i, r in enumerate(unique_context, start=1):
        source = r.node.metadata.get("file_name", "Unknown")
        text = r.node.get_content()

        context_info.append(f"[Source {i}: {source}]\n{text}")

    context = "\n\n".join(context_info)

    messages = [
        {"role": "system", "content": (
            "Answer only from the provided context. "

```

```

            "Cite the source number used. "
            "When the evidence is insufficient, refuse with this quote: 'I cannot answer this question from the provided documents'"
        )},

```

4. Test set (6 questions)

```

s > hw04 > ! questions.yaml
- id: q1
  type: one_chunk
  question: "What is a session and what is its purpose?"
  expected_answer: "A session is a logical conversation between a web server and a browser that spans multiple requests and responses."
  expected_sources:
    - "source3.txt"

- id: q2
  type: two_chunks
  question: "How does FastAPI session management work, including where session data is stored and how SessionMiddleware handles it?"
  expected_answer: "FastAPI can use cookie-based or server-side sessions. In a server-side session, session data can be stored in memory or a database."
  expected_sources:
    - "source3.txt"

- id: q3
  type: similar_across_documents
  question: "What is the difference between prompt engineering and context engineering?"
  expected_answer: "Prompt engineering focuses on how the model is asked, including instructions, constraints, examples, and output format. Context engineering focuses on how the model is given information, including the format and content of the context."
  expected_sources:
    - "source4.txt"
    - "source5.txt"

- id: q4
  type: ambiguous
  question: "How is state maintained?"
  expected_answer: "State can refer to session state, which maintains user information across requests, or React application/component state, which maintains information across function calls."
  expected_sources:

```

Snippet of results (more in METRICS.md)

```

----- Session -----
--- NO RAG ---
The default network port used by PostgreSQL is 5432. This is the port on which PostgreSQL listens for incoming TCP/IP connections.

--- BASIC RAG ---
The default network port used by PostgreSQL is typically 5432. However, this can be changed by the system administrator during installation or configuration. If you need to check the current port PostgreSQL is using, you can typically do so by running the command netstat -tlnp | grep :5432 on a Unix-based system or netstat -tlnp | findstr /i "5432" on a Windows system, assuming PostgreSQL is running and listening on 5432.

If you need further assistance with PostgreSQL, such as connecting to it or managing its settings, feel free to ask!

--- CONTEXT-ENGINEERED RAG ---
I cannot answer this question from the provided documents.
-----
q6: How can one survive the desert?
Retrieval latency: 529.40 ms
-----

```

5. The Context-Engineering RAG refused to answer the question at k=5, even though Question 3 should be able to, but they all remained above the relevance threshold. More context did not seem to improve results, and k=3 was the best for this situation, as it retrieved the chunks correctly and produced the correct answer without requiring additional context. k=1 is also a good contender, but as Question 3 specifically focuses on similar information across documents, I would choose k=3 as the best k value.

Context Size Sweep - Q3

k	Chunks Retrieved	Chunks Kept	Chunks Dropped by Relevance Filter	Basic RAG Result	Context RAG Result
1	1	1	0	Correct	Correct
3	3	3	0	Correct	Correct
5	5	5	0	Correct	Incorrect

```

for k in [1, 3, 5]:
    print("\n" + "-" * 60)
    print(f"k value: {k}")

    results = retriever_helper(index, query, k=k)

    #BasicRag and ContextEngRag
    basic_result = basic_rag(query, results)
    context_result = context_rag(query, results)

    print("\n----- Basic RAG Answer: -----")
    print(basic_result["content"])

    print("\n----- Context-Engineered RAG Answer: -----")
    print(context_result["content"])

```

6.

RAG Evaluation

Question	Configuration	Correct Retrieval	Correct Answer	Grounded	Refused When Needed
Q1	No RAG	N/A	Yes	N/A	N/A
Q1	Basic RAG	Yes	Yes	Yes	N/A
Q1	Context-Engineered RAG	Yes	Yes	Yes	N/A
Q2	No RAG	N/A	No	N/A	N/A
Q2	Basic RAG	Yes	Yes	Yes	N/A
Q2	Context-Engineered RAG	Yes	Yes	Yes	N/A
Q3	No RAG	N/A	Yes	N/A	N/A
Q3	Basic RAG	Yes	Yes	Yes	N/A
Q3	Context-Engineered RAG	Yes	Yes	Yes	N/A
Q4	No RAG	N/A	Yes	N/A	N/A
Q4	Basic RAG	No	No	Yes	N/A
Q4	Context-Engineered RAG	No	No	Yes	N/A

```

def main():

    eval_results.append({
        "question_id": qid,
        "configuration": "No RAG",
        "correct_retrieval": None,
        "correct_answer": None,
        "grounded": None,
        "refused_when_needed": no_rag_refusal,
        "answer": no_rag_result["content"],
    })

    eval_results.append({
        "question_id": qid,
        "configuration": "Basic RAG",
        "correct_retrieval": correct_retrieval,
        "correct_answer": None,
        "grounded": None,
        "refused_when_needed": basic_rag_refusal,
        "retrieved_chunks": retrieved_chunks,
        "retrieved_sources": retrieved_sources,
        "answer": basic_rag_result["content"],
    })

    eval_results.append({
        "question_id": qid,
        "configuration": "Context-Engineered RAG"

```

7. Based on my observation, questions 1 to 3 retrieved the correct chunks, whereas questions 4-6 did not. Additionally, question 4 only retrieved one source out of two, and missed the other source it should have returned. As for question 5, it retrieved the wrong chunks altogether. For question 6, there was also a situation where unrelated chunks were retrieved for question 6, and Basic RAG produced an answer with information that is unsupported with the context. Hallucinations or unsupported generations occurred in the No-RAG and Basic RAG configurations for questions 5 and 6 specifically. To improve the application, context changes were utilized and the specific changes that helped in this assignment were relevance filtering and the addition of grounding rules. For question 5 and 6, the Basic RAG answered while using information that was not supported, and the Context-Engineering RAG was able to avoid these hallucinations because of the grounding rules that have been included, showing the impact that it had in making improvements. Additionally, the relevance filtering helped decrease 3 chunks to 1 when it is lower than the 0.30 threshold for question 5, and for question 6, there was significant information shown as it refused to produce a result when the Context-Engineering RAG received zero chunks due to filtering. De-duplication on the other hand, did not help in making improvements as there were no chunks that have been removed as duplicates in our situation. In terms of the sweep, the results showed

that more context is not always beneficial, which is reflected when comparing $k=3$ to $k=5$. The answers shown in $k=1$ and $k=3$ were correct, while Context-Engineering RAG's answer to $k=5$ was not.

While making these observations, I noticed that prompt quality can have a significant impact in the quality of final answers. While good prompting can help prevent creating wrong answers (such as question 5 and 6), context-engineering rag was not able to completely fix the issue of bad retrievals.

In the future, some other tests that may be tested to determine an optimal chunk size is to try something else other than chunk size of 500 and overlap of 50.